



eu-academy-exams-2 should not be used on 23/4 (10:00-11:00 UTC). Please use eu-academy-exams-1

We now understand the basic use of `ffuf` through the utilization of wordlists and keywords. Next, we will learn how to locate pages.

Note: We can spawn the same target from the previous section for this section's examples as well.

We now understand the basic use of **ffuf** through the utilization of wordlists and keywords. Next, we will learn how to locate pages.

Note: We can spawn the same target from the previous section for this section's examples as well.

Extension Fuzzing

In the previous section, we found that we had access to `/blog`, but the directory returned an empty page, and we cannot manually locate any links or pages. So, we will once again utilize web fuzzing to see if the directory contains any hidden pages. However, before we start, we must find out what types of pages the website uses, like `.html`, `.aspx`, `.php`, or something else.

One common way to identify that is by finding the server type through the HTTP response headers and guessing the extension. For example, if the server is **apache**, then it may be **.php**, or if it was **IIS**, then it could be **.asp** or **.aspx**, and so on. This method is not very practical, though. So, we will again utilize **ffuf** to fuzz the extension, similar to how we fuzzed for directories. Instead of placing the **FUZZ** keyword where the directory name would be, we would place it where the extension would be **.FUZZ**, and use a wordlist for common extensions. We can utilize the following wordlist in **SecLists** for extensions:

Page Fuzzing

```
dbcyph0n@htb[/htb]$ ffuf -w /opt/useful/SecLists/Discovery/Web-Content/web-extensions.txt:FUZZ <SNIP>
```

Before we start fuzzing, we must specify which file that extension would be at the end of! We can always use two wordlists and have a unique keyword for each, and then do `FUZZ_1.FUZZ_2` to fuzz for both. However, there is one file we can always find in most websites, which is `index.*`, so we will use it as our file and fuzz extensions on it.

Note: The wordlist we chose already contains a dot (.), so we will not have to add the dot after "index" in our fuzzing.

Now, we can rerun our command, carefully placing our **FUZZ** keyword where the extension would be after **index**:

Page Fuzzing

```
dbcyph0n@htb[/htb]$ ffuf -w /opt/useful/SecLists/Discovery/Web-Content/web-extensions.txt:FUZZ -u http://SERVE
```

/'---\ /'---\ /'---\
 /\ _/\ /\ _/\ __ __ /\ _/
 \ \ ,--\\ \ \ ,--\\ \ \ / \ \ \ \ ,--\\
 \ \ _/\ \ \ _/\ \ _/\ \ \ _/\ \ _/
 \ \ \ \ \ ____/\ \ _
 _/ _/ ____/\ _/

v1.1.0-git

```

:: Method      : GET
:: URL         : http://SERVER_IP:PORT/blog/indexFUZZ
:: Wordlist     : FUZZ: /opt/useful/SecLists/Discovery/Web-Content/web-extensions.txt
:: Follow redirects : false

```

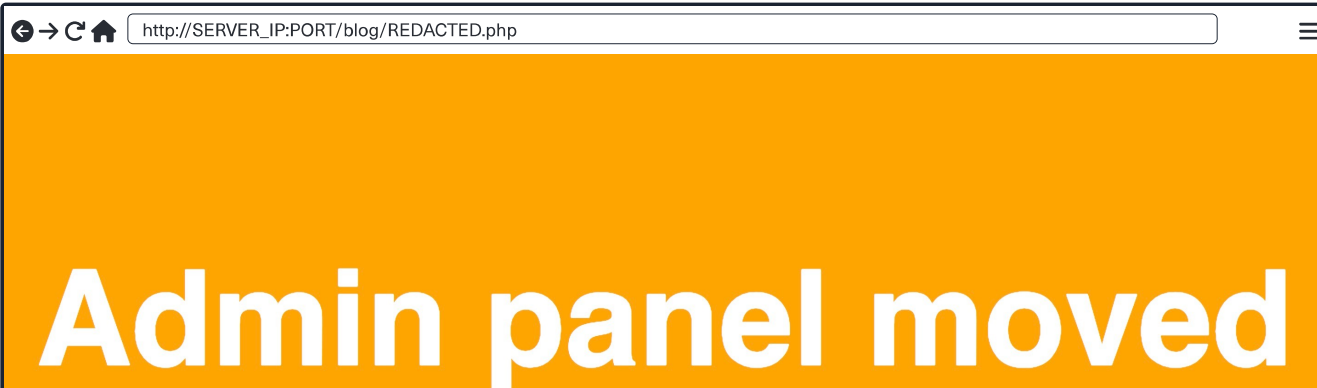


eu-academy-exams-2 should not be used on 23/4 (10:00-11:00 UTC). Please use eu-academy-exams-1

We do get a couple of hits, but only `.php` gives us a response with code `200`. Great! We now know that this website runs on `PHP` to start fuzzing for `PHP` files.

We will now use the same concept of keywords we've been using with `ffuf`, use `.php` as the extension, place our `FUZZ` keyword where the filename should be, and use the same wordlist we used for fuzzing directories:

We get a couple of hits; both have an HTTP code 200, meaning we can access them. index.php has a size of 0, indicating that it is an empty page, while the other does not, which means that it has content. We can visit any of these pages to verify this:



**Exams VPN Scheduled Maintenance eu-academy-exams-2**

eu-academy-exams-2 should not be used on 23/4 (10:00-11:00 UTC). Please use eu-academy-exams-1

Pwnbox Location

AU

218ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Cheat Sheet

Answer the question(s) below to complete this Section and earn cubes!

Target: 94.237.57.59:43030

Life Left: 63 minute(s)

+ 1

Try to use what you learned in this section to fuzz the '/blog' directory and find all pages. One of them should contain a flag.

What is the flag?

Submit

Hint

Previous

Next

Cheat Sheet



Exams VPN Scheduled Maintenance eu-academy-exams-2

eu-academy-exams-2 should not be used on 23/4 (10:00-11:00 UTC). Please use eu-academy-exams-1

Introduction

Introduction



Web Fuzzing



Basic Fuzzing

Directory Fuzzing



Page Fuzzing

Recursive Fuzzing

Domain Fuzzing

DNS Records

Sub-domain Fuzzing

Vhost Fuzzing

Filtering Results

Parameter Fuzzing

Parameter Fuzzing - GET

Parameter Fuzzing - POST

Value Fuzzing

Skills Assessment

Skills Assessment - Web Fuzzing

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left